Projet d'atelier – Jakarta EE 11 / WildFly 42 / Java 25

EduSecure

Plateforme sécurisée de protection et de traçabilité
des documents pédagogiques

Cahier des charges

Fonctionnel et technique – Version 1.0

Réalisé par : EZZINE Montassar

BEN FADHEL Zayd

OUNI Mouhamed Amine

Encadrant : Mohamed-Becha KAANICHE

Date : 6 novembre 2026

Statut : Proposition initiale soumise à validation

Informations du document

Élément	Valeur
Nom du projet	EduSecure
Type	Cahier des charges fonctionnel et technique
Version	1.0 – conception initiale
Public cible	Enseignants et étudiants, toutes spécialités
Déploiement visé	Prototype académique SPA/PWA avec middleware Jakarta EE
Référentiel lié	Recueil des besoins fonctionnels et SRE (document distinct)
Traçabilité	Dépôt GitHub de l'équipe ; PDF à placer sous `docs/`

Note de validation. Ce document formalise l'idée retenue par le trinôme. Les choix techniques et valeurs indicatives du prototype doivent être confirmés avec l'encadrant avant de figer la première itération. Les exigences de sécurité évolueront avec l'agenda du cours.

Table des matières

Informations du document i

1 Contexte et justification 1

2 Objectifs du projet 1

3 Parties prenantes et acteurs 2

4 Périmètre fonctionnel et limites 2

5 Description détaillée des services métier 3

6 Architecture technique 4

7 Scénario métier principal : publication d'un cours 5

8 Exigences fonctionnelles du cahier des charges 6

9 Règles métier 7

10 Exigences non fonctionnelles et contraintes 7

11 Contraintes et risques de sécurité 7

12 Recette et critères d'acceptation 8

13 Organisation et plan de réalisation 9

14 Livrables et organisation GitHub 9

15 Conclusion 10

1 Contexte et justification

1.1 Contexte général

Les établissements universitaires diffusent quotidiennement des cours, travaux dirigés, travaux pratiques, sujets d'évaluation, corrigés et supports administratifs. Les solutions ordinaires de partage de fichiers facilitent la distribution, mais n'assurent pas nécessairement l'identification du propriétaire, la différenciation des copies distribuées ni la protection des documents après une exposition du stockage.

1.2 Problématique

Comment offrir aux enseignants un service simple de publication de documents qui permette simultanément : (i) d'indiquer la provenance d'une ressource, (ii) de distinguer les copies destinées à différents étudiants, (iii) de protéger les documents au repos et (iv) de récupérer les fichiers de manière contrôlée sans conserver leurs clés symétriques en clair dans le stockage ?

1.3 Solution proposée

EduSecure est une application web SPA/PWA dans laquelle l'enseignant dépose un document et choisit les destinataires. Le serveur réalise automatiquement quatre familles de traitements :

1. **Watermarking :** apposition d'un filigrane commun identifiant la provenance du document ;
2. **Fingerprinting :** production d'une copie individualisée et traçable pour chaque étudiant ;
3. **Chiffrement hybride :** chiffrement des copies avec AES-256-GCM et protection de chaque clé AES avec la clé publique du destinataire ;
4. **Stéganographie :** insertion de la clé AES *déjà chiffrée* dans une image PNG porteuse.

Le serveur conserve le fichier chiffré, l'image porteuse et les métadonnées de distribution. L'étudiant récupère automatiquement les éléments autorisés ; son navigateur extrait la clé protégée depuis l'image, la déchiffre localement à l'aide de sa clé privée puis affiche le document.

Limite fondamentale : puisque le serveur réalise les opérations de watermarking, de fingerprinting et de chiffrement, il voit temporairement le document et la clé AES en clair. Le modèle retenu est celui d'un *serveur de traitement de confiance*, et non d'un chiffrement de bout en bout intégral.

2 Objectifs du projet

2.1 Objectif général

Concevoir et développer un prototype EduSecure répondant aux contraintes de l'atelier : SPA/PWA côté client, Jakarta EE 11 / WildFly 42 / Java 25 côté middleware, avec des services métier centrés sur la dissimulation et la protection de l'information, et des exigences de sécurité précisées dès la conception.

2.2 Objectifs spécifiques

1. Gérer les identités et distinguer les rôles enseignant, étudiant et administrateur.
2. Publier des ressources pédagogiques vers des destinataires explicitement sélectionnés.
3. Appliquer un watermark et vérifier sa présence sur un document PDF.
4. Générer des fingerprints individualisés et permettre une recherche de copie distribuée.
5. Générer une clé AES aléatoire distincte par copie, chiffrer et protéger la clé.
6. Dissimuler la clé AES chiffrée dans un PNG, puis vérifier qu'elle peut être récupérée sans altération.

7. Garantir un contrôle d'accès serveur sur les deux fichiers d'une même distribution.
8. Proposer une récupération transparente pour l'étudiant sans envoyer sa clé privée au serveur.
9. Tenir un historique minimal des opérations pertinentes pour l'audit et la maintenance des exigences.

3 Parties prenantes et acteurs

Acteur	Responsabilités et attentes
Enseignant	Déposer une ressource, renseigner son contexte, choisir les destinataires, visualiser la progression, vérifier le watermark, analyser une copie suspecte et consulter l'historique.
Étudiant	S'authentifier, enregistrer une clé publique vérifiée, conserver sa clé privée, consulter ses ressources, télécharger et ouvrir les documents attribués.
Administrateur	Gérer les comptes, les rôles, les paramètres de service, les quotas, les journaux et la disponibilité, sans disposer des clés privées des étudiants.
Système EduSecure	Appliquer les traitements métier, gérer les clés de données pendant le chiffrement, stocker les fichiers protégés et faire respecter les autorisations.
Encadrant	Valider le périmètre, les choix d'architecture, la justification métier et la qualité des livrables académiques.

4 Périmètre fonctionnel et limites

4.1 Périmètre de la première version (MVP)

- Authentification et accès distincts pour enseignant, étudiant et administrateur.
- Téléversement de fichiers PDF dans une plage de taille définie pour le prototype.
- Watermark visible ou semi-transparent configurable, appliqué au document.
- Fingerprinting : copie personnalisée par étudiant avec mécanisme de vérification adapté à la démonstration.
- Chiffrement AES-256-GCM côté serveur ; protection de la clé AES par RSA-OAEP.
- Stéganographie LSB dans un PNG servant exclusivement de transport de clé *chiffrée*.
- Stockage privé, association des fichiers, téléchargement contrôlé et déchiffrement local automatique.
- Historique de publication et analyse d'une copie suspecte.

4.2 Hors périmètre initial

- Hébergement public à grande échelle et interconnexion directe avec Moodle/Open edX.
- Chiffrement de bout en bout empêchant le serveur de traitement de voir les fichiers lors de la publication.
- Garantie d'un watermark ou fingerprint impossible à supprimer ; seul un niveau de robustesse testé sera annoncé.
- Support systématique des vidéos, flux audio ou formats bureautiques autres que PDF.
- Révocation rétroactive d'un fichier déjà téléchargé et sauvegardé en clair par un étudiant.

4.3 Hypothèses de cadrage

Le MVP suppose des utilisateurs de démonstration, un navigateur moderne, un serveur de traitement administré par l'équipe, et des documents PDF de taille limitée (valeur initiale proposée : 10 MiB, à valider par les tests). Chaque étudiant reçoit une copie unique. L'ajout d'un destinataire après publication pourra nécessiter un nouveau dépôt du fichier original, car le serveur ne conservera pas durablement de version en clair.

5 Description détaillée des services métier

5.1 Module Watermarking

Le serveur insère une marque de provenance dans le PDF avant la production des copies individualisées. Les paramètres possibles incluent le texte, un logo, l'opacité, la position et le périmètre des pages. Le résultat doit rester lisible. Le professeur peut demander une vérification de la présence de la marque.

Exemple : « Université – Support pédagogique – 2026 » appliqué sur toutes les pages. La marque est commune à toutes les copies d'une même publication.

5.2 Module Fingerprinting

Pour chaque destinataire, le serveur génère une copie marquée avec une empreinte distincte. Une association entre document, identifiant de distribution, empreinte et destinataire est conservée dans un registre sécurisé. Le module d'analyse permet de tenter de retrouver une empreinte dans une copie suspecte et de remonter à la distribution initiale.

Règle de prudence : une empreinte retrouvée identifie une *copie distribuée*, pas nécessairement la personne responsable de sa divulgation. La résistance aux transformations (copie, conversion, compression) sera documentée par des tests.

5.3 Module de stéganographie des clés

La stéganographie a ici **une fonction unique** : cacher dans une image PNG une clé AES qui a déjà été protégée par RSA-OAEP. Le système vérifie la capacité du support, insère le contenu binaire, puis réalise une extraction de contrôle avant l'enregistrement. L'image doit être conservée et servie sans recompression ni conversion destructive.

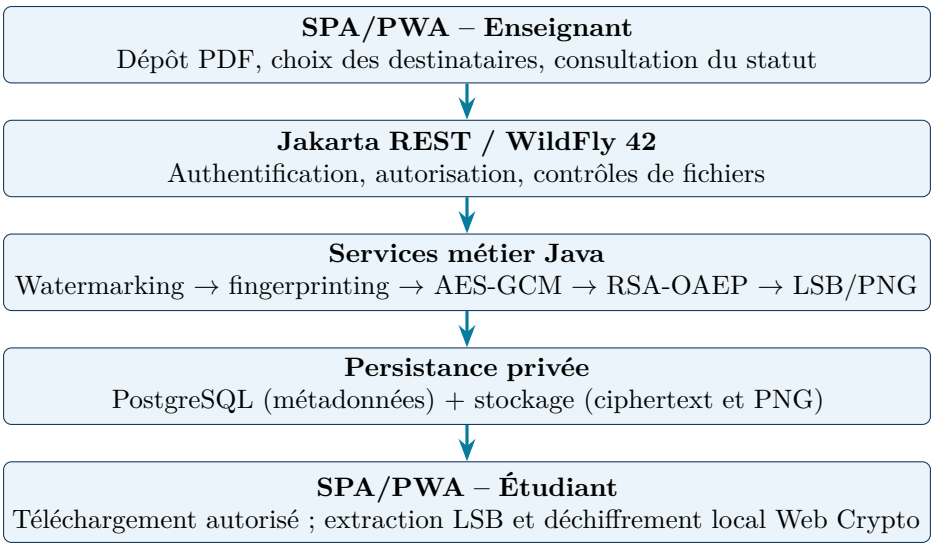
Invariance de sécurité : jamais de clé AES en clair dans les pixels de l'image, le nom de fichier, les métadonnées stockées ou les journaux. La confidentialité provient du chiffrement asymétrique, pas de la seule dissimulation.

5.4 Distribution sécurisée

L'application associe à chaque étudiant deux objets liés : la copie chiffrée et le PNG porteur de clé chiffrée. L'API doit appliquer un contrôle d'accès sur *les deux* objets. L'étudiant ne manipule pas d'algorithmes : après son authentification et le déverrouillage éventuel de sa clé privée locale, son navigateur gère automatiquement l'extraction et le déchiffrement.

6 Architecture technique

6.1 Vue d'ensemble



6.2 Technologies proposées

Couche	Choix proposé / responsabilité
Frontend	SPA/PWA React , interfaces des acteurs et intégration Web Crypto côté étudiant.
Middleware	Jakarta EE 11 / WildFly 42 / Java 25, API REST, gestion des utilisateurs et orchestration métier.
Traitement PDF	Bibliothèque Java dédiée au PDF, sélectionnée après un prototype technique de watermarking et fingerprinting.
Cryptographie	Fournisseur cryptographique Java standard : génération sûre, AES-256-GCM, RSA-OAEP.
Stéganographie	Implémentation Java du procédé LSB sur PNG non destructif, avec extraction et test de capacité.
Base de données	PostgreSQL : comptes, clés publiques, documents, distributions, empreintes, événements.
Stockage	Stockage privé local ou objet de type MinIO ; aucun accès direct public au contenu.
Automatisation	Git/GitHub ; tests automatisés ; conteneurisation éventuelle pour la reproductibilité.

6.3 Modèle simplifié de données

Entité	Informations principales
Utilisateur	Identifiant, nom, email, rôle, statut, paramètres d'authentification.
ClePublique	Utilisateur, identifiant de clé, algorithme, clé publique, empreinte de vérification, statut.
Document	Propriétaire, titre, type MIME, taille, date, watermark, statut de publication.
Distribution	Document, destinataire, identifiant de copie, empreinte, état, date d'attribution.
ObjetProtege	Référence au fichier chiffré, référence au PNG, paramètres AES et version du format.
EvenementAudit	Acteur, action, ressource, date, résultat, contexte technique non sensible.

7 Scénario métier principal : publication d'un cours

7.1 Préconditions

Le professeur possède un compte actif. Les trois étudiants sont inscrits et disposent d'une clé publique authentifiée. Le document est au format PDF et respecte les limites applicatives.

7.2 Déroulement nominal

Étape 1. Le professeur se connecte, importe `Cours_Statistiques.pdf` et choisit Amine, Mohamed et Sarra.

Étape 2. L'API vérifie le rôle du professeur, le type réel du fichier, sa taille et ses paramètres.

Étape 3. Le module watermarking ajoute la marque commune identifiant l'établissement.

Étape 4. Le fingerprinting crée trois versions individualisées : F_A, F_M et F_S.

Étape 5. Pour chaque étudiant i, le serveur génère une clé aléatoire K_i de 256 bits.

Étape 6. Il chiffre F_i avec AES-256-GCM, un nonce approprié et des données associées liant le fichier à sa distribution :

$$C_i = \text{AES-GCM.Enc}_{K_i}(F_i; N_i, AAD_i).$$

Étape 7. Il récupère la clé publique authentifiée PK_i et protège K_i :

$$W_i = \text{RSA-OAEP.Enc}_{PK_i}(K_i).$$

Étape 8. Il dissimule W_i dans une image PNG porteuse par LSB et vérifie son extraction exacte.

Étape 9. Il conserve C_i, le PNG, le nonce et les métadonnées. Aucun document ni secret en clair n'est conservé dans le stockage permanent.

Étape 10. Le système affiche la publication comme réussie, avec les trois distributions créées.

7.3 Récupération par un étudiant

Amine ouvre son tableau de bord et choisit le cours. Le serveur contrôle son droit d'accès aux deux objets. Le navigateur extrait W_A depuis le PNG, utilise sa clé privée locale SK_A pour retrouver K_A, puis déchiffre C_A avec AES-GCM. Le document n'est affiché que si toutes les vérifications réussissent.

7.4 Scénarios alternatifs et erreurs

- **Clé publique absente ou non vérifiée :** publication suspendue pour le destinataire concerné.
- **Fichier invalide ou trop volumineux :** rejet motivé, sans stockage du fichier brut.
- **Capacité PNG insuffisante :** le système choisit un autre support ou interrompt la distribution.
- **PNG modifié ou extraction incorrecte :** aucun document n'est affiché ; événement technique enregistré.
- **Clé privée incorrecte :** échec du déchiffrement asymétrique et message d'erreur non révélateur.
- **Ciphertext altéré :** échec de l'authentification AES-GCM, sans afficher de contenu partiel.
- **Étudiant non autorisé :** accès refusé par le serveur indépendamment de la possession d'une URL.

8 Exigences fonctionnelles du cahier des charges

ID	Fonction	Résultat attendu / critère d'acceptation
F-01	Gestion des sessions	L'utilisateur accède à une interface conforme à son rôle et ne peut utiliser une fonction interdite.
F-02	Gestion des clés publiques	Une clé publique vérifiée est associée à l'identité de chaque étudiant destinataire.
F-03	Dépôt de PDF	Le serveur accepte un PDF autorisé et refuse un fichier invalide ou dépassant la limite.
F-04	Choix des destinataires	L'enseignant sélectionne explicitement un ou plusieurs étudiants avant publication.
F-05	Watermarking	Un filigrane commun est présent dans les pages du document marqué.
F-06	Vérification watermark	Le service indique la présence d'une marque reconnue ou l'impossibilité de conclure.
F-07	Fingerprinting	Chaque destinataire reçoit une copie portant une empreinte distincte.
F-08	Recherche de copie	Une copie de test intacte permet de retrouver la distribution qui lui correspond.
F-09	Génération AES	Le serveur génère une nouvelle clé AES pour chaque copie publiée.
F-10	Chiffrement PDF	Le PDF marqué est chiffré avec AES-GCM, avec paramètres de déchiffrement conservés.
F-11	Protection asymétrique	La clé AES de chaque copie est protégée avec la clé publique du destinataire.
F-12	Stéganographie	La clé AES *chiffrée* est dissimulée dans un PNG et extraite à l'identique.
F-13	Persistance	Le système associe de façon cohérente fichier chiffré, image porteuse et métadonnées.
F-14	Liste des ressources	L'étudiant visualise uniquement les documents qui lui sont attribués.
F-15	Récupération	Le navigateur déchiffre automatiquement avec la clé privée locale et affiche le PDF.
F-16	Historique	Le professeur consulte l'état et les événements de ses distributions.
F-17	Audit de copie suspecte	Le professeur obtient un résultat de recherche d'empreinte avec statut de validité.
F-18	Administration	Un administrateur gère comptes et quotas sans obtenir les clés privées.

9 Règles métier

RM-1. Une publication est créée par un enseignant authentifié et liée à un ensemble explicite de destinataires.

RM-2. Le watermark identifie le propriétaire et reste commun aux copies d'une publication.

RM-3. Chaque copie distribuée reçoit une empreinte unique, associée à un seul destinataire pour la distribution considérée.

RM-4. La production d'une copie, son chiffrement et la création de son image porteuse forment une opération cohérente : un résultat incomplet n'est pas publié.

RM-5. La clé AES de chiffrement du fichier est aléatoire, spécifique à la copie et protégée avant insertion stéganographique.

RM-6. Le serveur ne conserve pas la clé privée des étudiants ni une clé AES en clair dans son stockage permanent.

RM-7. Le document chiffré et son PNG sont inséparables d'un point de vue logique : droits d'accès et sauvegardes portent sur les deux éléments.

RM-8. L'analyse d'un fingerprint identifie une copie et ne constitue pas, à elle seule, une preuve de responsabilité de son destinataire.

RM-9. La révocation d'accès empêche de nouveaux téléchargements mais n'efface pas les copies déjà récupérées hors ligne.

10 Exigences non fonctionnelles et contraintes

Dimension	Attente et proposition de vérification
Ergonomie	Publication en un parcours guidé ; aucune manipulation manuelle des algorithmes cryptographiques par les utilisateurs.
Compatibilité	Interface responsive ; navigation sur un navigateur récent ; fonctionnalités PWA définies sans cache automatique des fichiers déchiffrés.
Performance	Objectif provisoire : démonstration fluide sur des PDF allant jusqu'à 10 MiB ; métriques et seuils définitifs à mesurer en environnement de TP.
Disponibilité	Échec propre et reprise possible après une interruption ; fichiers chiffrés et PNG sauvegardés conjointement.
Maintenabilité	Modules métier séparés, API documentées, tests unitaires et d'intégration, suivi GitHub des modifications.
Observabilité	Journalisation des publications, refus d'accès, erreurs de traitement et incidents sans exposer de secret.
Interopérabilité	Services REST, stockage privé et schéma de métadonnées versionné.
Sécurité	Validation des uploads, HTTPS, contrôle d'accès par ressource, intégrité AES-GCM et protection des clés.

11 Contraintes et risques de sécurité

Modèle de confiance : le serveur de traitement a accès temporairement au document et à la clé AES durant la publication. La protection contre un serveur activement compromis pendant cette phase n'est pas assurée par l'architecture actuelle. Cette limite doit être déclarée et analysée dans le document SRE.

Menace ou contrainte	Mesure prévue / limite
Vol des données stockées	Ciphertexts AES-GCM et clés asymétriquement protégées ; aucun original en clair conservé.
Extraction du message caché	L'attaquant retrouve seulement la clé AES *chiffrée*, inutilisable sans la clé privée du destinataire.
Substitution de clé publique	Vérification de l'association compte–clé publique avant chaque publication.
Accès horizontal non autorisé	Contrôle d'accès sur chaque document, image et métadonnée ; tests d'accès croisé.
Altération du ciphertext	Échec de vérification AES-GCM avant tout affichage du PDF.
Image PNG altérée ou convertie	Conservation binaire exacte ; test d'extraction après insertion et sauvegarde.
PDF malveillant	Validation des types et tailles, limites de traitement et isolement du composant de parsing.
Suppression du fingerprint	Évaluer la résistance aux transformations retenues ; ne pas annoncer de garantie absolue.
Perte de clé privée	Définir une procédure de sauvegarde/renouvellement ; impossibilité éventuelle de lire les anciens fichiers.
Compromission du serveur pendant publication	Risque résiduel : exposition possible du PDF clair et de la clé AES transitoire.

11.1 Lien avec le recueil SRE

Le second livrable développera les exigences précises portant sur l'identification/authentification, l'autorisation, la confidentialité, l'intégrité, la non-répudiation, les audits, la détection d'abus et la disponibilité. La démarche envisagée combine SQUARE pour la structuration des exigences, STRIDE pour la modélisation des menaces et les Misuse Cases pour les scénarios adverses. Chaque exigence devra être liée à des risques et à des tests d'acceptation.

12 Recette et critères d'acceptation

ID	Essai	Résultat attendu
T-01	Publication d'un PDF pour trois étudiants	Trois copies différentes, un watermark commun et trois distributions cohérentes.
T-02	Contrôle de l'empreinte de chaque copie	Correspondance avec le destinataire de démonstration prévu.
T-03	Inspection des fichiers stockés	Aucun PDF clair ni clé AES en clair présent dans le stockage permanent.
T-04	Extraction depuis le PNG de chaque étudiant	La valeur protégée récupérée est identique à celle insérée.
T-05	Déchiffrement avec la bonne clé privée	Le document personnalisé est restitué correctement.
T-06	Déchiffrement avec une mauvaise clé privée	La récupération échoue ; le PDF n'est pas affiché.
T-07	Modification de quelques octets du ciphertext	La vérification d'intégrité échoue.
T-08	Téléchargement du fichier d'un autre étudiant	Requête refusée par l'API.

ID	Essai	Résultat attendu
T-09	Changement/recompression du PNG	Erreur d'extraction détectée et restituée proprement.
T-10	Dépôt de faux PDF ou fichier trop gros	Rejet sans persistance du contenu brut.
T-11	Analyse d'une copie suspecte intacte	Empreinte retrouvée et distribution associée affichée.
T-12	Inspection des journaux	Aucun secret, clé privée ou contenu pédagogique en clair journalisé.

13 Organisation et plan de réalisation

13.1 Répartition prévisionnelle du trinôme

Membre	Responsabilité principale proposée
EZZINE Montassar	Architecture générale, conception SRE, API et intégration des services de sécurité.
BEN FADHEL Zayd	Services documentaires de watermarking/fingerprinting et vérification des copies.
OUNI Mouhamed Amine	Module stéganographique PNG, parcours SPA/PWA et tests d'intégration de récupération.

Cette distribution est indicative et doit être validée par l'équipe ; les tests de sécurité et les revues de code restent une responsabilité partagée.

13.2 Jalons prévisionnels

Phase	Livraison attendue
Semaine 1	Dépôt GitHub, cahier des charges PDF, recueil des besoins fonctionnels et SRE PDF.
Conception	Modèle de données, cas d'utilisation, schéma des flux, choix des algorithmes et premiers tests de faisabilité.
MVP métier	Watermarking, fingerprinting et stéganographie LSB isolés et testés.
Intégration	Jakarta EE, stockage privé, chiffrement serveur, distribution et récupération côté client.
Validation	Recette fonctionnelle, tests de sécurité, documentation des limites, démonstration.

14 Livrables et organisation GitHub

Le dépôt GitHub constitue la référence de progression et d'historique de l'équipe. Le répertoire `docs/` doit contenir, dès la prochaine séance, les deux PDF obligatoires :

- `docs/Cahier_des_charges.pdf` (ce document compilé) ;
- `docs/Recueil_des_besoins_Fonctionnels_SRE.pdf` (document distinct).

Arborescence cible indicative :

```
EduSecure/
  docs/
    Cahier_des_charges.pdf
    Recueil_des_besoins_Fonctionnels_SRE.pdf
    sources_latex/
  frontend/
  backend/
  tests/
  README.md
```

15 Conclusion

EduSecure propose une distribution de documents pédagogiques qui réunit trois techniques complémentaires : watermarking pour la provenance, fingerprinting pour la traçabilité individuelle et stéganographie pour le transport discret des clés AES *déjà chiffrées*. Les opérations de protection du document sont réalisées par le serveur Jakarta EE, de manière transparente pour le professeur, tandis que la clé privée de l'étudiant reste locale et sert au déchiffrement automatique dans le navigateur. Le cahier des charges fixe un MVP réalisable par un trinôme, ainsi que les contraintes et limites qui devront être approfondies dans le recueil SRE.